

CYBERSÉCURITÉ

**QUELLE SERAIT UNE RÉPONSE
ADÉQUATE FACE
À UN INCIDENT DE SÉCURITÉ
INFORMATIQUE ?**

Sommaire

- Introduction sur l'incident de sécurité
- Processus de réaction aux menaces informatiques
- Gestion de crise
- Prestataires de réponse sur incident de sécurité
- Elaboration du processus de réaction

Enseignant-chercheur à Université Paul Sabatier (STRI – SSIR – SSIR & IRIT)

Dirigeant de la société CYBERFABLAB Expertises et formations

Expert de justice E-INDUSTRIE (Informatique section E01.02 à E01.04) & CRIMINALISTIQUE (G-02.05)

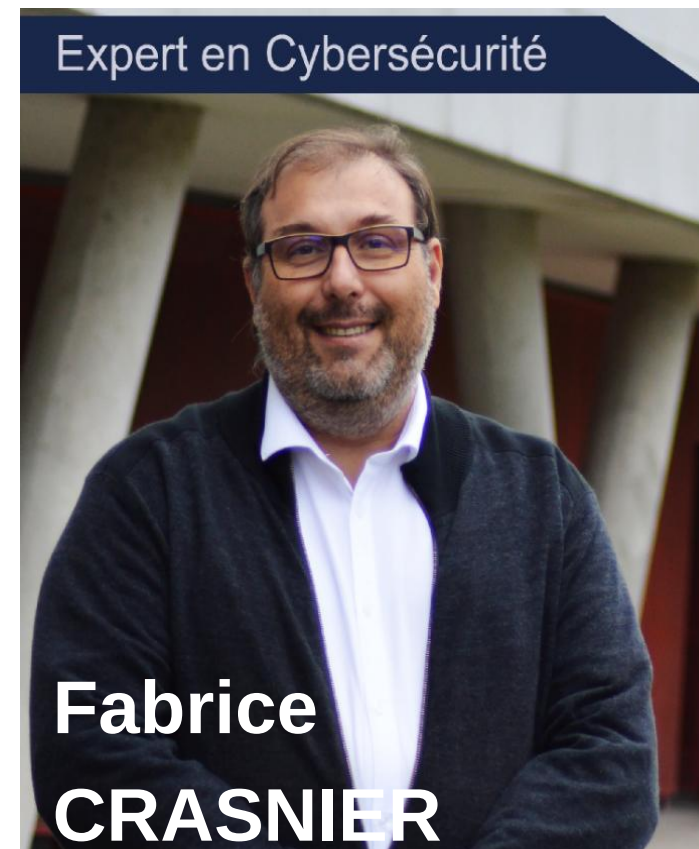
Après un cursus **d'Ingénieur en conception et développement** informatique, je me suis dirigé vers la recherche sur l'informatique embarqué puis sur l'apprentissage automatique supervisé. A cet effet, je termine un **doctorat en intelligence artificielle** distribuée à l'école doctoral de Toulouse.

Durant 27 ans au service des unités de recherches de la Gendarmerie Nationale, dont 17 années consacrées au suivi de la cyberdélinquance en tant **enquêteur NTECH**, j'ai mis en place les équipes d'investigations en cybercriminalité de la section des recherches à partir de 2002 et de la section d'appui judiciaire de Toulouse à compter de 2013.

A partir de 2017, j'ai pu mettre en place le laboratoire SCASSI-CYBER en qualité de **Consultant Expert Senior** au sein de la société SCASSI, où j'ai exercé durant 3 ans au poste de responsable des activités de réponse sur incidents de sécurité et des expertises légales (FORENSIC) puis durant un an environ en tant que **directeur de la recherche et du développement** au sein de la société FREEMINTRONIC à Andorre.

Je suis actuellement **enseignant-chercheur** à l'université Paul Sabatier à TOULOUSE en tant que **Maître de conférences associé** où j'enseigne diverses matières en lien avec la cybersécurité allant de l'audit de maturité au recours devant les tribunaux pour les activités de cybercriminalité. Je mène en parallèle mon activité de **dirigeant** d'entreprise dans la recherche et le développement nommée **CYBERFABLAB** et celle **d'expert de justice auprès de la Cour d'Appel de TOULOUSE**

Expert en Cybersécurité



**Fabrice
CRASNIER**

4

La sécurité du système informatique

**Vous êtes tous très
performants dans votre
domaine.**



Ingénieur en développement



Ingénieur en maintenance

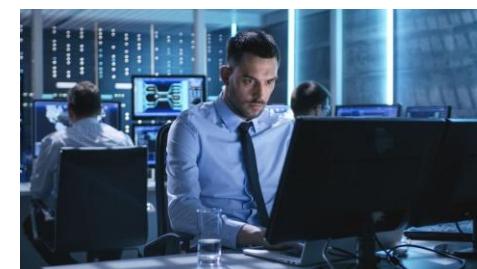


Ingénieur en architecture



Ingénieur en système

**Vous êtes des
informaticiens à forte
valeur ajoutée pour votre
DSI**



Ingénieur en supervision

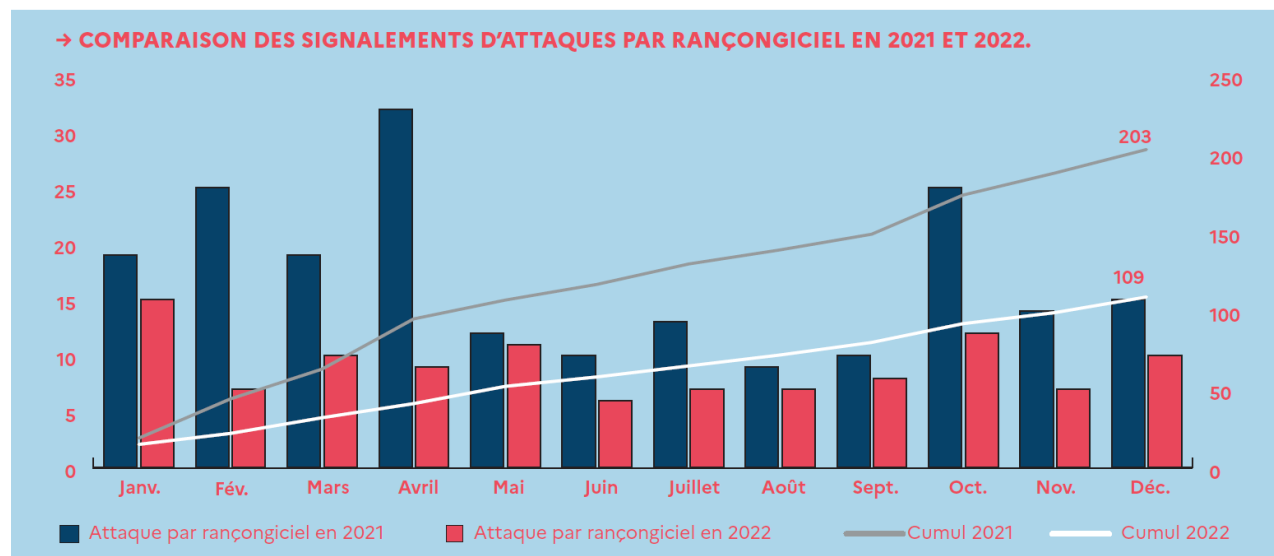
5

Que s'est-il passé de nouveau en 2022 ?

Rien de vraiment nouveau sur la
typologie de la cybercriminalité



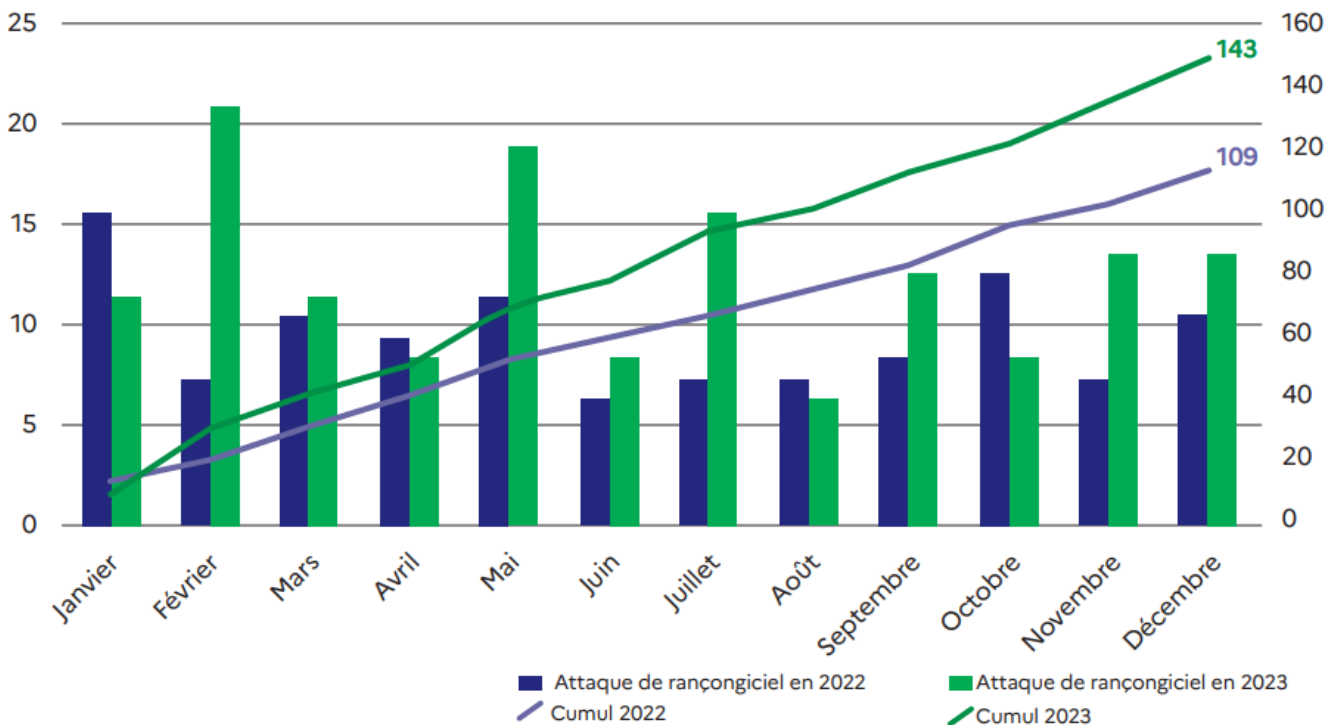
Les fuites de données, les infiltrations de réseaux,
le vol et la vente de données en masse, le vol
d'identité et les **demandes de rançon**



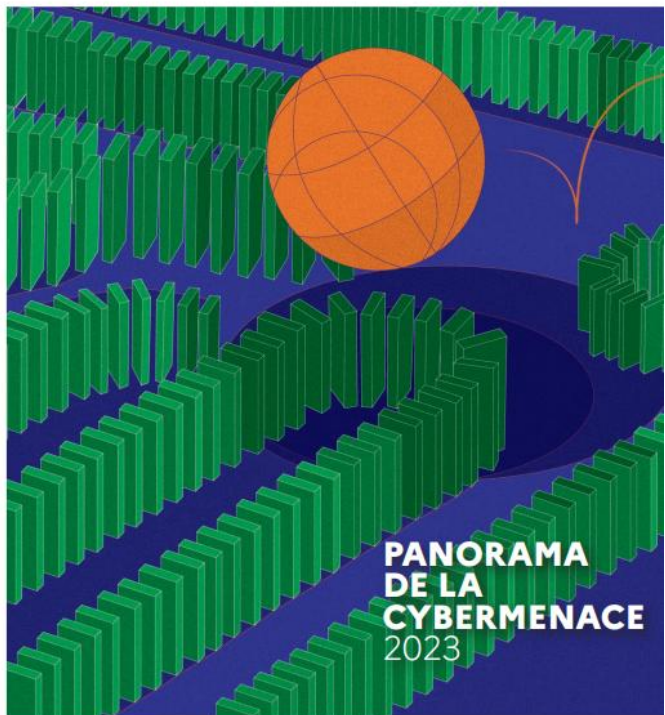
SOURCES : <https://www.cert.ssi.gouv.fr/cti/CERTFR-2023-CTI-001/>

à noter!

→ Comparaison des signalements d'attaques par rançongiciel en 2022 et 2023



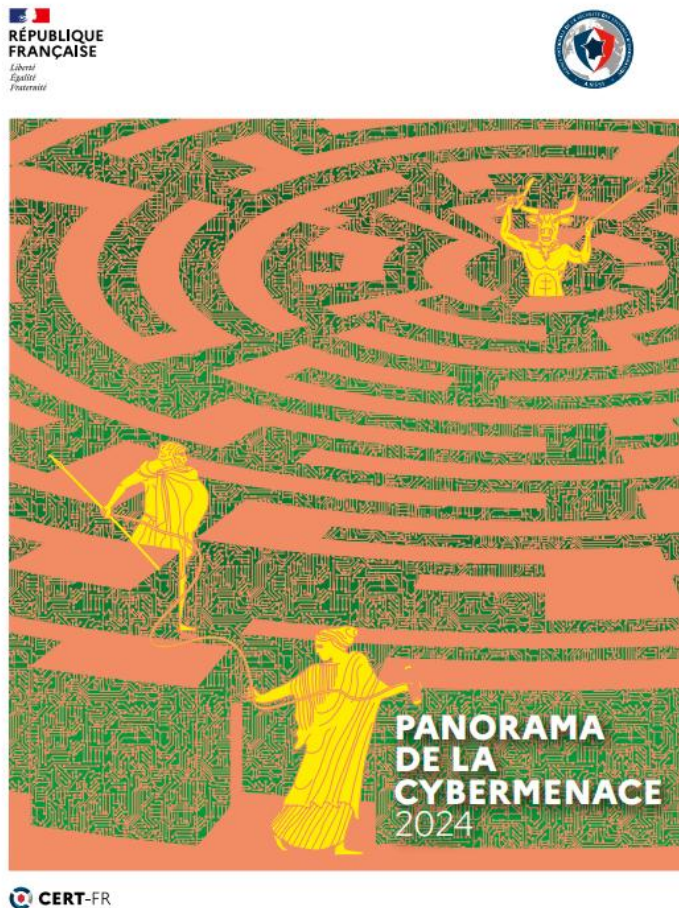
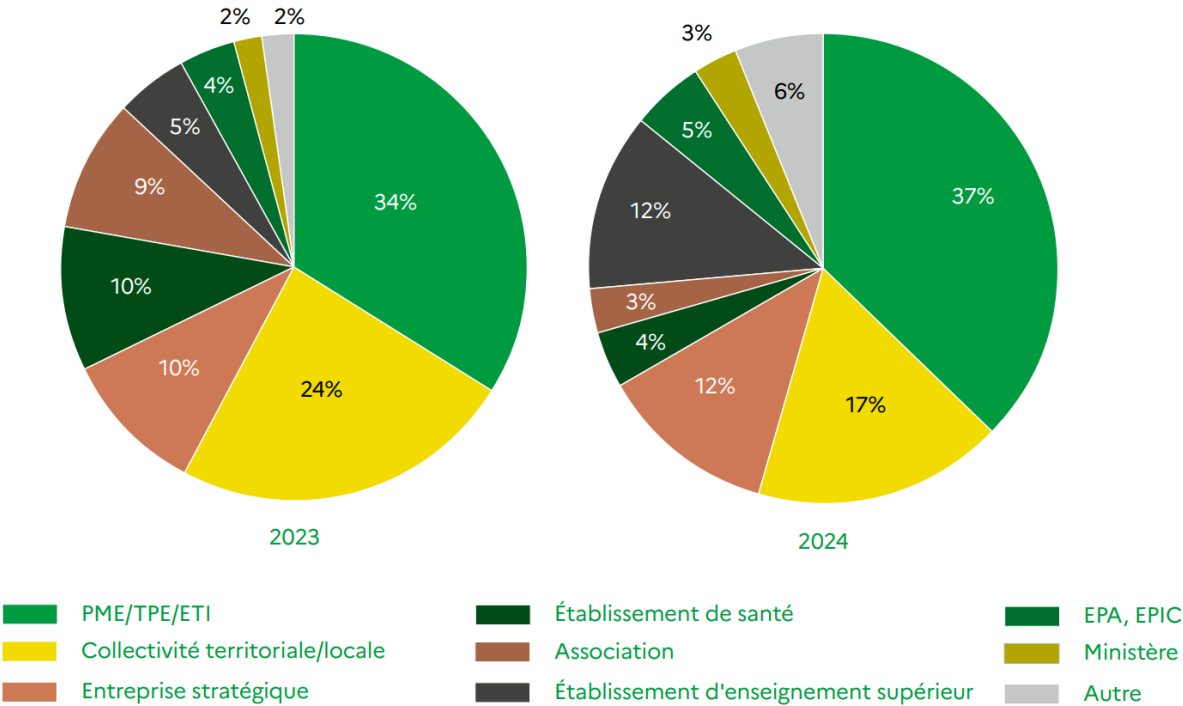
RÉPUBLIQUE
FRANÇAISE
Liberté
Égalité
Fraternité



SOURCES : <https://www.cert.ssi.gouv.fr/uploads/CERTFR-2024-CTI-001.pdf>

à noter!

Répartition des victimes d'attaques par le biais de rançongiciels



SOURCES : <https://www.cert.ssi.gouv.fr/uploads/CERTFR-2025-CTI-003.pdf/>

8

Les quatorze impacts d'une cyberattaque

Un large panel de coûts directs / indirects entrent en ligne de compte pour mesurer l'impact financier d'un cyberincident

à noter!

Une sous-estimation du risque financier



La sécurité du système informatique



10

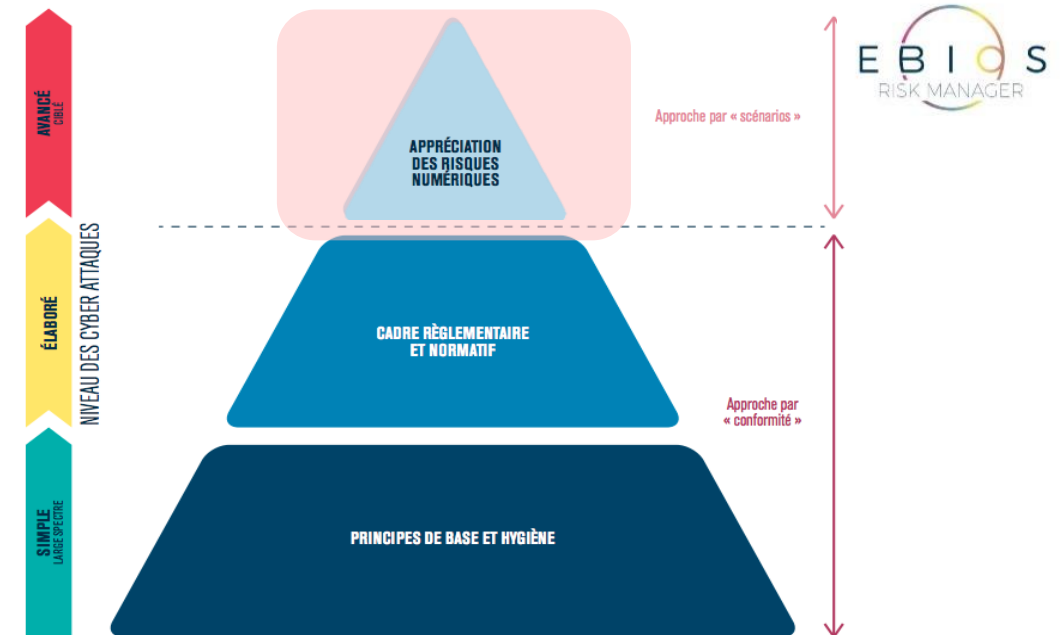
Ne pouvant éviter le danger
il faut apprendre à minimiser son impact



Ce qu'il nous faut éviter à tout prix

14/04/2025

Fabrice CRASNIER, Consultant expert sénior en Cybersécurité



Formation et préparation à l'incident

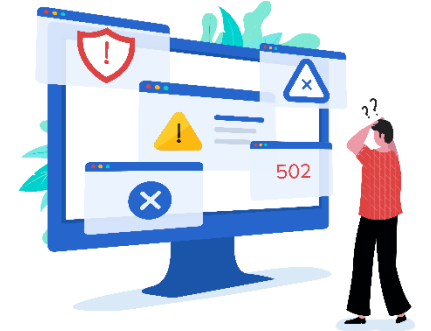
Réponse sur incident



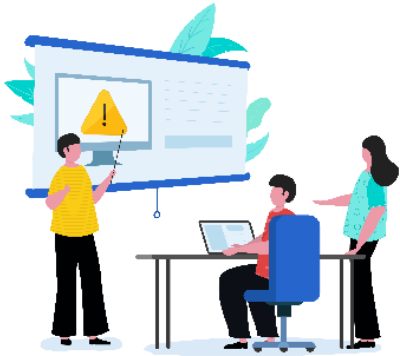
12

Qu'est-ce que la réponse sur incident de sécurité?

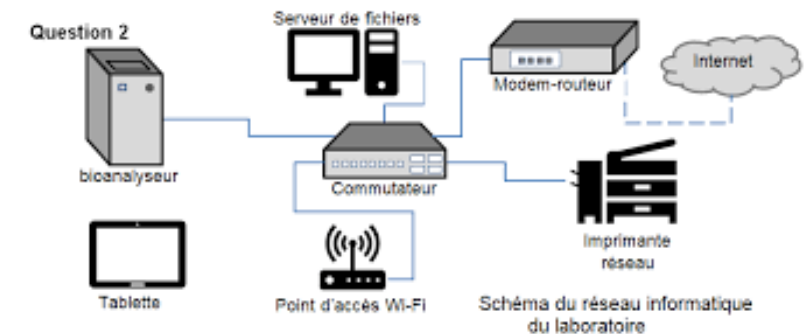
Nous sommes **vendredi, il est 17H30** et tout semble normal dans votre service d'assistance. Soudain, vous recevez un ticket d'alerte indiquant qu'un service essentiel est en panne, et **dans les 15 minutes** qui suivent, vous commencez à recevoir un afflux de tickets signalant le même problème. **Les services de votre système d'information tombent les uns après les autres.**



13

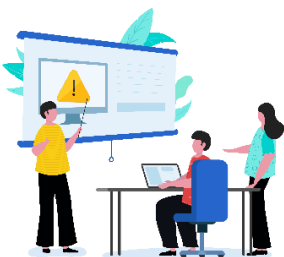


Ne pouvant éviter le danger
il faut apprendre à minimiser
son impact



14

ITIL (Information Technology Infrastructure Library) est un ensemble d'ouvrages recensant les bonnes pratiques du management du système d'information.



- les pratiques de gestion générales,
- les pratiques de gestion des services
- les pratiques de gestion technique.



La façon dont vous réagissez à un incident majeur est cruciale pour minimiser son impact et rétablir les services (cf. Gestion des incidents majeurs dans ITIL).

15 Gardons à l'esprit

Répondre aux incidents de sécurité **c'est répondre à une attaque avec des processus, des services et des personnes adéquats**. La question est donc de savoir dans quelle mesure notre service informatique est **prêt à gérer les incidents de sécurité** ?

La réponse à incident est un **processus pluridisciplinaire** qui doit faire partie intégrante de la stratégie de sécurité globale et de la politique d'atténuation du risque qui n'est donc pas à la charge unique d'un seul service.



16 Gardons à l'esprit

Ainsi, outre les services informatiques, la gestion de la crise doit également **impliquer des juristes, des représentants des ressources humaines et de la communication.**

NE RESTER PAS SEUL FACE AUX DÉCISIONS À PRENDRE

Tous les services de l'entreprise doivent apprendre de travailler de concert avec les équipes IT et de sécurité, afin s'assurer que l'entreprise traverse la crise en subissant le **moins d'impact possible.**



Déclencheur de la réponse sur incident de sécurité?

incident de sécurité



A quel moment
la réponse sur incident de
sécurité intervient-elle ?

"Houston on a un problème !".

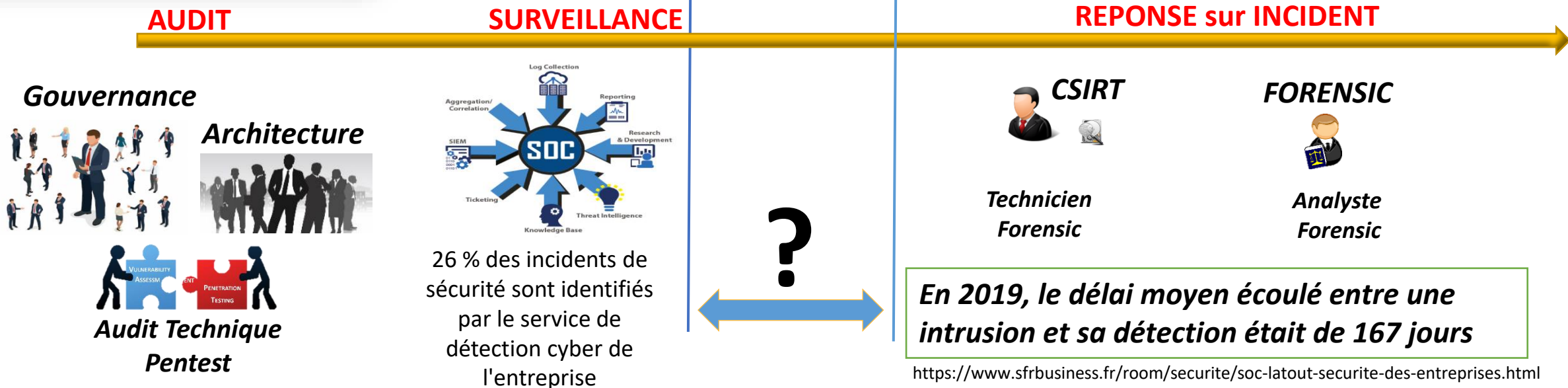


(Apollo XIII en 1970)

A quel moment la réponse sur incident intervient-elle ?

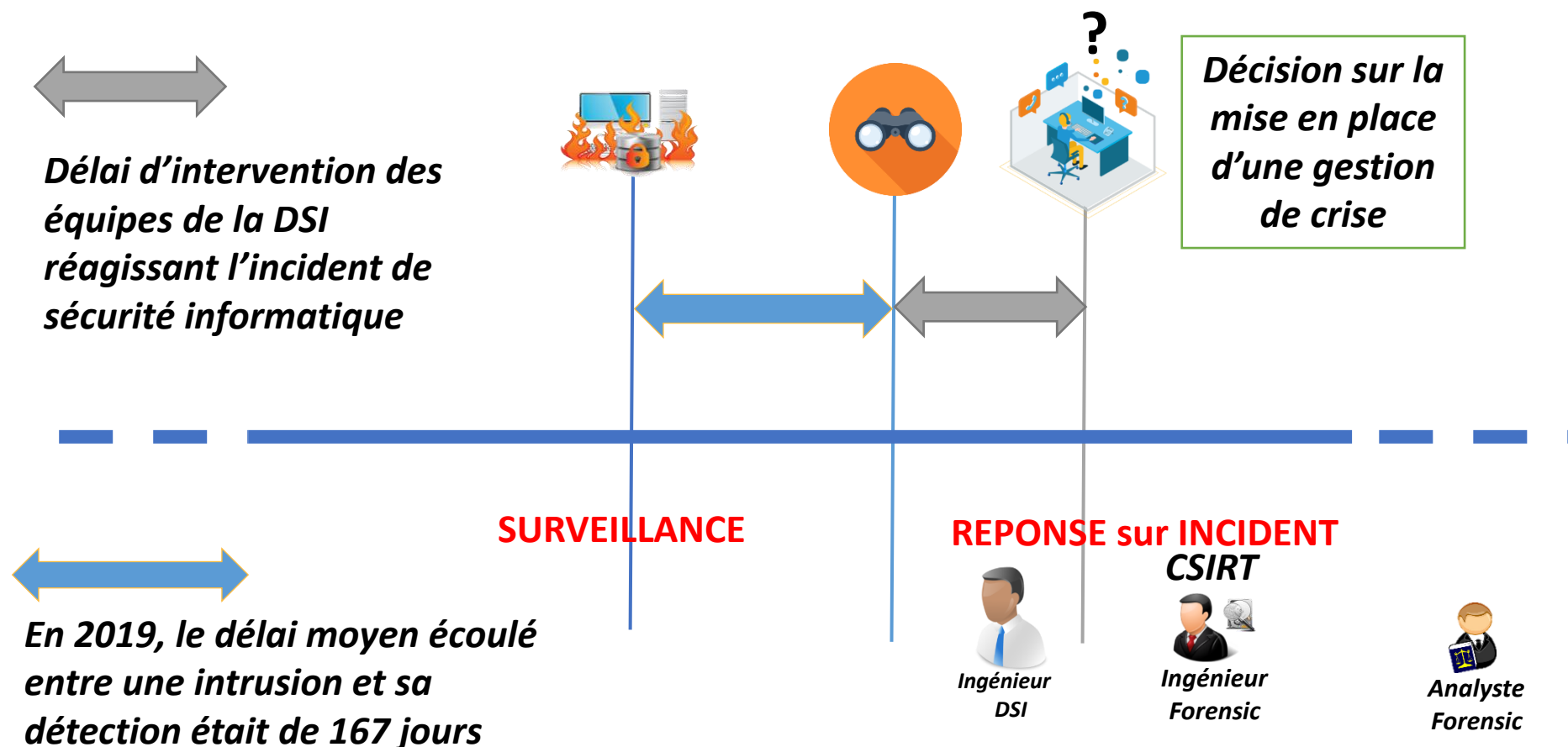


PASSI	Prestataire d'audit de la sécurité des systèmes d'information
PDIS	Prestataire de détection d'incidents de sécurité
PRIS	Prestataire de réponse aux incidents de sécurité



19

A quel moment la réponse sur incident intervient-elle ?



la gestion de crise



Réponse sur incident





La gestion de crise

La **gestion de crise cyber** est un processus structuré et organisé qui permet à une organisation de réagir et de gérer efficacement les incidents de cybersécurité ou les crises ayant un impact sur ses actifs numériques, ses opérations ou sa réputation.

La gestion de crise cyber vise à **réduire l'impact des incidents de cybersécurité**, à **protéger les actifs** et la **réputation** de l'entreprise, et à **garantir la continuité des activités** face aux menaces numériques.

SOURCES : <https://www.ssi.gouv.fr/guide/crise-dorigine-cyber-les-cles-dune-gestion-operationnelle>





La gestion de crise

En tant que **Responsable de la Sécurité des Systèmes d'Information (RSSI)**, votre rôle dans la gestion de crise cyber comprend plusieurs aspects clés :

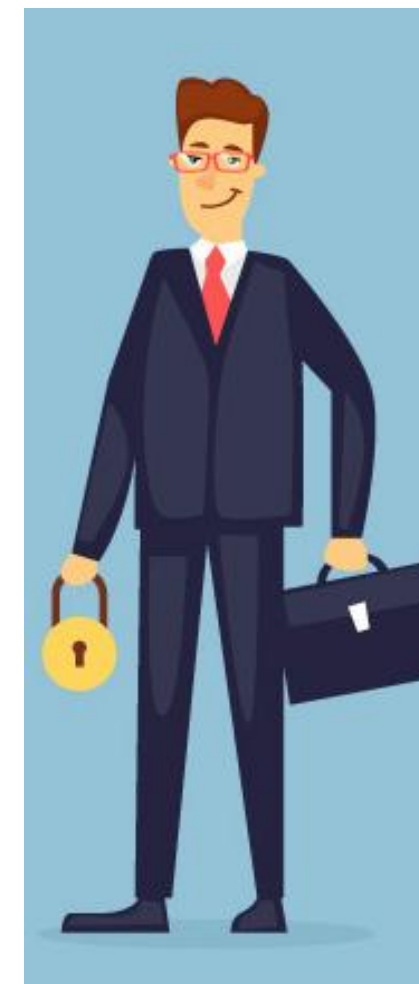
1. **Préparation** : Établir un plan de réponse aux incidents de cybersécurité, incluant la formation et la sensibilisation du personnel, l'identification des parties prenantes et la définition des procédures à suivre en cas d'incident.
2. **Détection** : Mettre en place des mécanismes de surveillance et de détection pour identifier rapidement les menaces potentielles et les incidents de cybersécurité.
3. **Limitation** : Lorsqu'un incident est détecté, prendre des mesures pour contenir l'impact et prévenir la propagation de la menace à d'autres systèmes ou actifs.





La gestion de crise

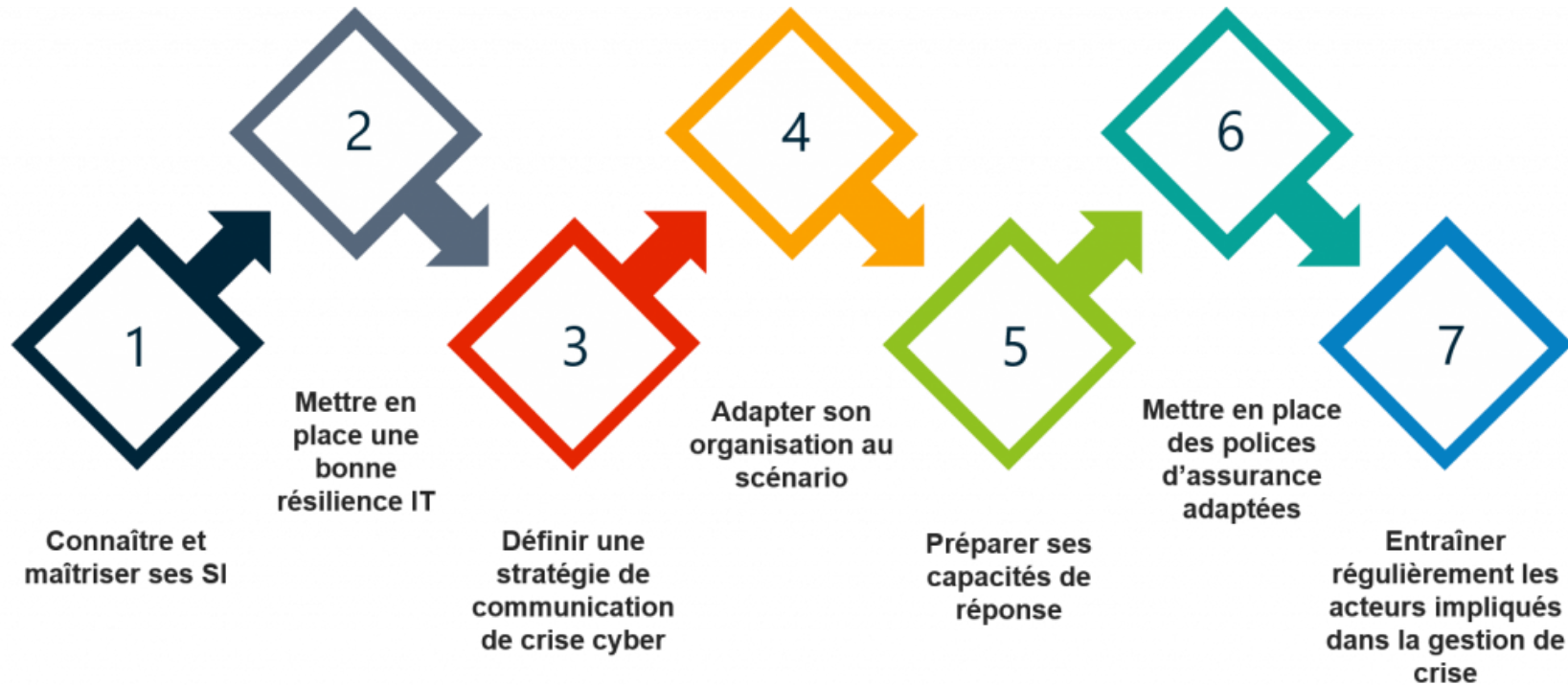
4. **Éradication** : Identifier et éliminer la source de l'incident, y compris la suppression de logiciels malveillants, la réparation de vulnérabilités et la restauration des systèmes compromis.
5. **Récupération** : Restaurer les systèmes et les données affectées, en veillant à ce que les opérations reprennent de manière sécurisée et en minimisant les perturbations pour l'entreprise.
6. **Analyse et apprentissage** : Après la résolution d'un incident, mener une analyse approfondie pour déterminer les causes sous-jacentes, évaluer la gestion de la crise et identifier les leçons à tirer pour améliorer les processus et les défenses de l'organisation.



24



La gestion de crise



La gestion de crise

La **cellule de crise** est un groupe de personnes clés réunies pour gérer et coordonner la réponse à un **incident majeur** ou une **situation d'urgence** dans une organisation.



La gestion de crise



Cette **équipe multidisciplinaire** est généralement composée de membres de la direction, de responsables de **différents départements** (comme les ressources humaines, les opérations, la communication, etc.), et d'experts techniques ou de spécialistes du domaine concerné (par exemple, la cybersécurité dans le cas d'un incident informatique).

La **mise en place d'une cellule** de crise permet à l'organisation de **réagir rapidement** et **efficacement** en cas de situation d'urgence, de **minimiser les impacts négatifs** et de **protéger ses actifs**, sa **réputation** et la **sécurité de ses employés**.



La gestion de crise

La cellule de crise a **plusieurs responsabilités**, notamment :

1. **Évaluer la situation** : Analyser rapidement les informations disponibles pour comprendre la nature, l'ampleur et l'impact de l'incident ou de la crise.
2. **Prendre des décisions** : Déterminer les mesures à prendre pour gérer la situation, en tenant compte des ressources disponibles, des priorités de l'organisation et des implications à court et long terme.



La gestion de crise

3. **Coordonner la réponse** : Veiller à ce que les différentes équipes et départements de l'organisation travaillent ensemble de manière efficace et cohérente pour mettre en œuvre les mesures décidées et résoudre la crise.
4. **Communiquer** : Informer les parties prenantes internes et externes (comme les employés, les clients, les fournisseurs et les autorités) sur la situation, les actions entreprises et les éventuelles conséquences ou perturbations.
5. **Suivi et évaluation** : Surveiller la mise en œuvre des actions, évaluer leur efficacité et ajuster la stratégie en fonction de l'évolution de la situation.



La gestion de crise

<https://www.ssi.gouv.fr>



Processus de réaction aux menaces informatiques



30

Réponse sur incident



PRESTATAIRES DE RÉPONSE AUX INCIDENTS DE SÉCURITÉ PRIS



31



Prestations et activités

PRESTATAIRES DE RÉPONSE AUX INCIDENTS DE SÉCURITÉ PRIS

Prestataires de réponse aux incidents de sécurité

Référentiel d'exigences

Version 3.0 du 28 juillet 2024

Le **référentiel d'exigences** relatif aux prestataires de réponse aux incidents de sécurité est un ensemble de règles qui s'imposent aux prestataires qui désirent obtenir une qualification de leurs services dans ce domaine.

SOURCES : https://cyber.gouv.fr/sites/default/files/document/PRIS_Referentiel-exigences_v3.0.pdf

Prestations et activités

Service

Advens

Type de service: PRIS

Nom du fournisseur: Advens

Date de fin de qualification: 27/09/2026

Service

Intrinsec Securite

Type de service: PRIS

Nom du fournisseur: Intrinsec Securite

Date de fin de qualification: 16/09/2025

Service

Lexfo

Type de service: PRIS Nom du fournisseur: Lexfo Date de début de qualification:

Niveau de recommandation: ✓ - Optimal

Service

Orange Cyberdefense

Type de service: PRIS

Nom du fournisseur: Orange Cyberdefense

Date de fin de qualification: 25/10/2027

Service

Wavestone

Type de service: PRIS

Nom du fournisseur: Wavestone

Date de fin de qualification: 29/06/2026

Service

PricewaterhouseCoopers Advisory

Type de service: PRIS

Nom du fournisseur: PricewaterhouseCoopers Advisory

Date de fin de qualification: 30/11/2026

Service

Sopra Steria Infrastructures and Security Services

Type de service: PRIS

Nom du fournisseur: Sopra

Date de début de qualification: 25/03/2024 Date de fin de qualification: 25/03/2027

SOURCES : https://cyber.gouv.fr/produits-services-qualifies?sort_bef_combine=nom_du_fournisseur_ASC&field_type_service_value%5Bpris%5D=pris&categorie_psq=

14/04/2025

Fabrice CRASNIER, Consultant expert sénior en Cybersécurité

PRESTATAIRES DE RÉPONSE AUX INCIDENTS DE SÉCURITÉ PRIS

Prestations et activités

incident de sécurité



PASSI

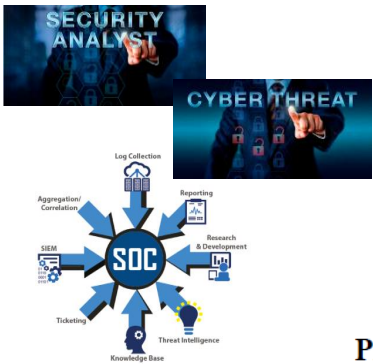
*Gouvernance
Audit Technique*



Pôle Architecture



PDIS



PASSI
PDIS
PRIS

PRIS



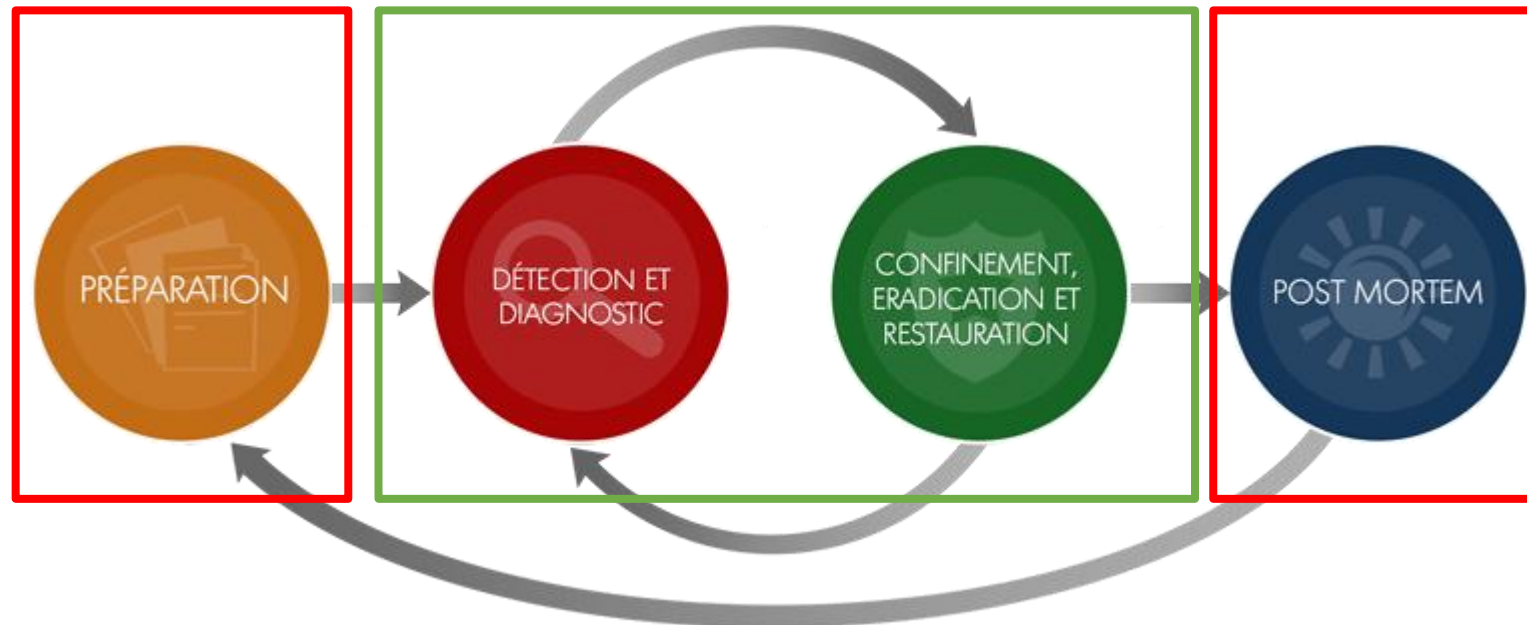
CSIRT

Prestataire d'audit de la sécurité des systèmes d'information
Prestataire de détection d'incidents de sécurité
Prestataire de réponse aux incidents de sécurité

FORENSIC



Processus de réponse aux incidents de sécurité





Établissement d'une convention

- ☐ Modalités de la prestation
- ☐ Organisation
- ☐ Responsabilités
- ☐ Confidentialité
- ☐ Lois et réglementations
- ☐ Sous-traitance
- ☐ Livrables
- ☐ Qualification

La convention de service doit :

- a) Être rédigée en français. Le prestataire doit fournir une traduction de courtoisie de la convention de service si le commanditaire en fait la demande ;
- b) Stipuler que seule la version française fait foi, notamment dans le cadre d'un litige ;
- c) Stipuler que la législation applicable à la convention de service est la législation française ;



Préparation de la prestation

Compréhension de la situation et de
l'environnement
Élaboration de la posture initiale

- ☐ Mise en place de l'organisation
- ☐ Mise en place des moyens opérationnels
- ☐ Mise en place de mesures de sauvegarde et de préservation
- ☐ Mise en place de procédures d'urgence

Prestations et activités

Les types de prestations (ANSSI):

- ☐ la **recherche** d'indicateurs de compromission **IOC**,
- ☐ l'**i**nvestigation numérique sur **p**érimètre restreint,
- ☐ l'**i**nvestigation numérique sur **large p**érimètre.

Activités

Pilotage technique
(Management)

Analyse réseau
(Log, Siem)

Analyse système
(OS, Machine)

**Analyse de codes
malveillants**
(Reverse)

Normes

ISO19011 - chapitre 7.2.3.4

ISO27035 - Gestion des incidents de sécurité de
l'information

ISO27037 - l'identification, la collecte, l'acquisition et la
préservation de preuves numériques

La réponse aux incidents de sécurité informatique

Indicateur de compromission pour DRIDEX

<https://www.cert.ssi.gouv.fr/cti/CERTFR-2020-CTI-005/>

malware	Dridex (botnet ID 199 ou 501)
size-in-bytes	162304
md5	7239da273d3a3bfd8d169119670bb745
sha1	f624d419671b8eef94241bd010a1ca0c22950fec
sha256	aadb5217c4c9316b90ce4eb5f2b52f72d34d426d66ce00c9addaef1654853acf
filenames	['Fiddler.exe']

malware	size-in-bytes	md5	sha1	sha256	filenames
Dridex (botnet ID 199 ou 501)	162304	7239da273d3a3bfd8d169119670bb745	f624d419671b8eef94241bd010a1ca0c22950fec	aadb5217c4c9316b90ce4eb5f2b52f72d34d426d66ce00c9addaef1654853acf	['Fiddler.exe']
Dridex (botnet ID 199 ou 501)	163328	72fe19810a9089cd1ec3ac5ddda22d3f	cecbd09b389a6f4e3ac7a81a9280e1893a6066ae	cd32a737fcb8a198d43fed5a68348f983f713f79574a710deb7759e5a1301eb	['Fiddler.exe']
Dridex (botnet ID 199 ou 501)	233472	07b0ce2dd0370392eedb0fc161c99dc7	abf30fe414f07060b95e49034f05f3e4698d71d8	13c5b3339522f8f96d091708e7a8a64b0939daa6225732352fba44cb2950e67	['api', 'apisets', 'FQbdHGT8.exe']
Dridex (botnet ID 199 ou 501)	180224	c8bb08283e55aed151417a9ad1bc7ad9	57f8fe479206f195b630cf8232a0c0e9c5a47977	6362084f61fa6a41b8b01b7c62215ad41a2623b69572ce558c33bffa21f0af9	['HPDJSLK', 'IA4DIPGM.EXE']
Dridex (botnet ID 199 ou 501)	1032192	6e05e84c7a993880409d7a0324c10e74	4cac8146d54c5e47ec1c31a04c3cafdec9fbf209	ffb1150bbb28d53f325b00445be935cd657c1d8061ba73e91af5b343b6cd438	['d3dx81ab.dll']
Dridex (botnet ID 199 ou 501)		63d4834f453ffd63336f0851a9d4c632			
Dridex (botnet ID 199 ou 501)	188416	0ef5c94779cd7861b5e872cd5e922311	5b4b7a6f33d3188ae5211a4432d2a5c84c1da10e	741087126c1c7edec3d0a3bc3f490723a4f410e9a278444c812e7f79013bb996	['QK9BAv2j.exe', 'HPDJSLK']
DoppelDridex (botnet ID 40300)	338944	9aa3089af134627ef48b178db606268a	1348d76072280a489cc8d6a15aeb3617b59585ba	06b8638fdd478672cfe140221233cacfae6d2890446a5c57c8b1317a27d2a036	['spLauncherâ€™,â€™0ev7Bg.binâ€™,â€™secpi15.exeâ€™]
Dridex	246816	e614a69d706913376ab2bb20a703dcf5	3a83bb68be29e1f18fc9d328d952fd228abfae2a	4fccd38f504290cf5c70e7336071a90a064303c7fd5c177c38001768bce115	['FreeStudioManager.exe']
Dridex (botnet ID 199)	212992	d0409052256c6fca85b155f58cc03f70	3ab42ca8ce81f9df0cf7cd807528c5dd0fb5108	1d778359ab155cb190b9f2a7086c3bcb4082aa195ff8f754dae2d665fd20aa05	['FIREFOX.TMP']
Dridex	273920	62fc2f7b571450e4d5e2cd1cb90f2d94	90106cf0242c1bd5b54bb3c598429a9266721cd	3bf00c028d3c6812f6f0c3c22d7474c0077dfcfbbbf6b518c1e6c07f972f2e7	['â€™.dllâ€™,â€™Wo.dllâ€™,â€™mVwEiAJObi.dllâ€™]
Dridex	1069056	3			â€™streams.exeâ€™,â€™DUI70.dllâ€™]
Dridex	786432	b			â€™streams.exeâ€™,â€™UxTheme.dllâ€™]
Dridex	782336	7			â€™streams.exeâ€™,â€™dxgi.dllâ€™]
Dridex	266416	323f7a38cd55ef78e2e2d9e037b0171f	f5e129381be88dddec7a17dc57ce138ff1f252423	a1388cb3e6ae68a6130ae12f9db4881238c97718875a3362b6bc5788e61c6663	['â€™Ibmm4rh4.exeâ€™,â€™aswBootâ€™,â€™aswBoot.exeâ€™]
Dridex	208896	6285579d7082c55871b4b9dbe735255a	13cbfa1d79184d1cea84aef59e5c856117fd91c2	ca087f46f97cd465f46e4ccb04181e6ae7b2c751ae7fd9e262191b979728ccc	['â€™VDIMEâ€™,â€™VDIME.DLLâ€™,â€™ktyaowm.binâ€™,â€™frllo.binâ€™]
Dridex	217088	c1986a52bc76c58ea099873f6464caf9	f1a543664d8872b53103e07ef659e45d3faa397c	4ad0998882a3bfd3412f0c740faebb8ef78bec4c3e566650424c40a87e6a23a	['â€™Caff54e1.exeâ€™,â€™ktyaowm.binâ€™,â€™pvmbihu.binâ€™]

Liste des indicateurs de compromission pour DRIDEX

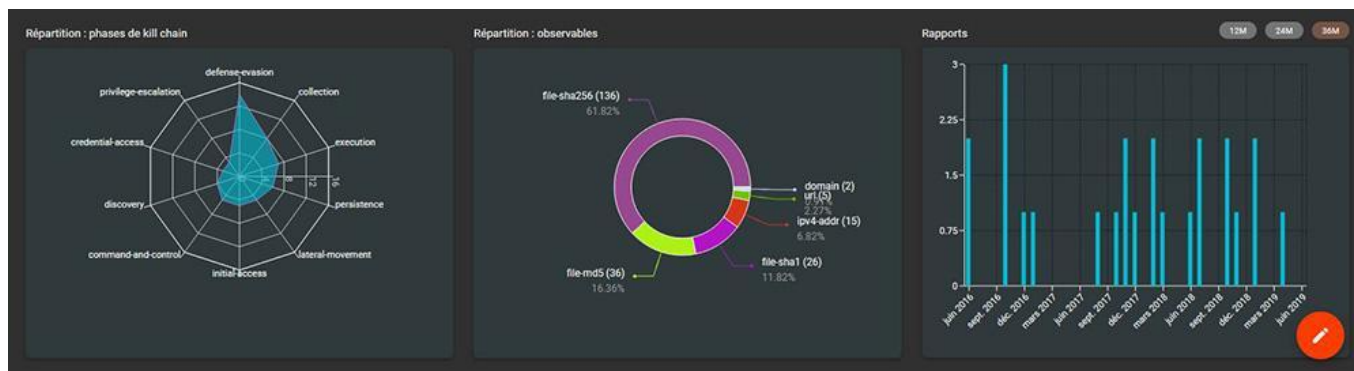
39

La détection d'incidents de sécurité informatique

OpenCTI
ANSSI

Un outil pour structurer, traiter et partager les connaissances

Le projet OpenCTI a été initié en septembre 2018 par l'ANSSI et co-développé avec le [CERT-EU](#)



<https://github.com/OpenCTI-Platform>

Indicateur de compromission est une combinaison d'informations techniques représentatives d'une manifestation de compromission, dont la présence peut être identifiée à partir de l'analyse d'un système, d'un code malveillant ou de traces réseau.

Exécution de la prestation



La démarche doit comprendre au moins les phases suivantes :

- **phase 1** : Révision de la compréhension de l'incident de sécurité et de l'environnement ;
- **phase 2** : révision de la posture (*élevé, moyen, faible*)
- **phase 3** : collecte des informations ;
- **phase 4** : analyse des informations collectées ;
- **phase 5** : synthèse des analyses et capitalisation des indicateurs de compromission ;
- **phase 6** : révision des mesures de remédiation.



Restitutions

Le responsable d'équipe d'analyse doit présenter au commanditaire une synthèse à jour concernant :

- ☐ la compréhension de l'incident;
- ☐ la posture adoptée;
- ☐ les opérations en cours de réalisation et réalisées
- ☐ les mesures de remédiation proposées.



**Positionnement à
la cellule de crise**

42



Restitutions



Le responsable d'équipe d'analyse doit assurer une restitution, il assure une restitution à la demande du commanditaire :

- ☐ **quotidiennement**, au référent désigné par le commanditaire
(voir Annexe 3 II, paragraphe a) ;
- ☐ à **chaque révision** de la posture ;
- ☐ à **l'issue de la prestation**, sans attendre que le rapport d'analyse soit achevé ;
- ☐ à la **clôture de la prestation**, après la livraison du rapport d'analyse, à la demande du commanditaire.

**Positionnement
à la cellule
technique**

43



Élaboration du rapport d'analyse

Une synthèse, **compréhensible par des non-experts**, qui précise :

- ☐ l'objectif de la recherche,
- ☐ l'(es) indicateur(s) de compromission recherché(s),
- ☐ le périmètre couvert par la recherche,
- ☐ les résultats de la recherche,
- ☐ la suite à donner à la recherche ;

44



Élaboration du rapport d'analyse

La **description des recherches** réalisées et de leurs résultats:

- ☐ les modes opératoires,
- ☐ les outils utilisés,
- ☐ les vrais positifs;

La **suite à donner** à la recherche, incluant :

- ☐ la justification des recommandations,
- ☐ les différentes options possibles, le cas échéant,
- ☐ la suite à donner (poursuivre avec une nouvelle prestation)

45



Cas des enquêtes judiciaires

Une enquête judiciaire est une action pénale, qui peut être déclenchée, à la demande ou non du commanditaire :

- ☐ antérieurement ou simultanément au démarrage de la prestation ;
- ☐ au cours de la prestation ;
- ☐ à la clôture ou postérieurement à la fin de la prestation.

Les objectifs des enquêteurs et du prestataire sont distincts, même si ils portent sur les mêmes faits.

Le **prestataire doit**, dans le cas d'une enquête judiciaire et conformément à la législation en vigueur sur le territoire français, **assurer une collaboration pleine et entière avec le service enquêteur**.

46

Missions et compétences attendues du personnel

La Team RI

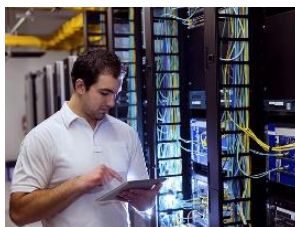
Le responsable
d'équipe
d'analyse



Le responsable
d'équipe
technique



Analyste réseau



Analyste système



Gestion de crise et
communication



Analyste de codes
malveillants



Juriste



Le personnel dédié à la RI

Missions et compétences attendues du personnel

Responsable d'équipe d'analyse doit assurer de multiples missions dont :

- ❑ La mise en œuvre une organisation adaptée aux objectifs,
- ❑ structurer l'équipe d'analystes (compétences, effectif),
- ❑ assurer la définition, le pilotage et le contrôle des activités des analystes,
- ❑ définir et gérer les priorités, en particulier en situation de crise ...



**Le responsable
d'équipe
d'analyse**

Missions et compétences attendues du personnel

Le responsable d'équipe technique doit avoir des compétences approfondies dans la plupart des domaines techniques :

- ☐ les principales attaques et activités malveillantes ,
- ☐ la connaissance des normes de référence pour la représentation des indicateurs de compromission,
- ☐ les architectures des systèmes d'informations d'envergure, leurs vulnérabilités et leurs mécanismes d'administration ...



**Le responsable
d'équipe
technique**

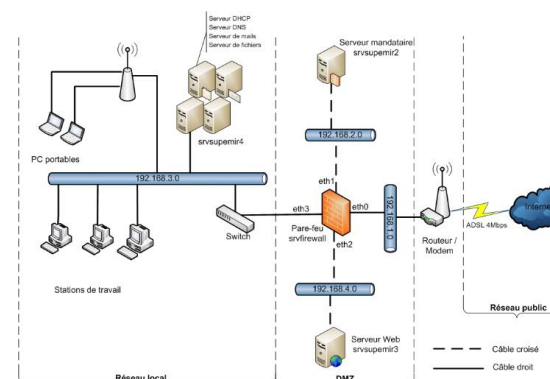
Prérequis à fournir par les commanditaires

Le commanditaire doit mettre à disposition du prestataire les informations concernant :

- ❑ l'organigramme de l'organisation ;
- ❑ l'organisation générale du système d'information ;
- ❑ l'architecture du système d'information
- ❑ les spécificités du système d'information
- ❑ le système d'information



**Le
commanditaire**



Prérequis à fournir par les commanditaires

Le commanditaire doit mettre à disposition du prestataire les informations concernant :

Mais aussi

- ❑ l'architecture des domaines d'administration et des liens entre les domaines
- ❑ la politique de journalisation, les moyens de supervision et de détection
- ❑ les périodes de gel technique et les projets en cours ou prévus pour le système d'information
- ❑ les éventuelles démarches déjà entreprises par le commanditaire
- ❑ les éventuels premiers résultats de la compréhension de l'incident de sécurité



Elaboration du processus de réaction aux menaces informatiques

Réponse sur incident



52



Il va falloir
répondre à des
questions ?

**Houston nous
avons un
problème !**



Que nous arrive-t-il ?

Qui est intervenu sur le sinistre ?

Quelle est la sensibilité des informations ?

Quelles sont les conséquences ? Etc.

Ouff !! Je sors mon guide
d'interventions urgences

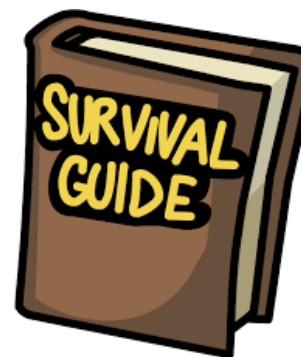
Euh!
On est mal,
pas sûr



Bonnes pratiques d'intervention de la DSI

Les guides d'intervention sont à la base du succès des activités de réponse sur incident car ce sont eux qui vont faire la différence dans la minimisation de l'impact d'une compromission du système d'information.

- Le guide du 1^{er} intervenant de permanence
- Le guide du 1^{er} intervenant de la DSI
- Le guide de la cellule d'urgence
- Le guide de la cellule de crise

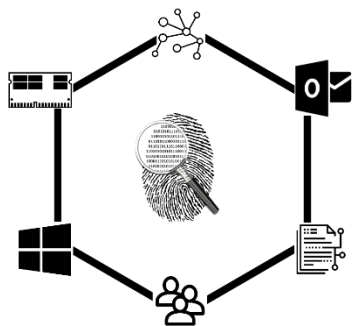


Prêt à
intervenir



54

Qu'est-ce que la réponse sur incident de sécurité?



1

Posture

Cellule de crise



2

**Protection
des preuves**

*numériques des
machines identifiées*



4

**Mesures
conservatoires**

*Copies forensiques des
supports compromis*



3

Scan et analyses

Infrastructure et réseaux



5

**Analyse
post mortem**

*Analyse des
supports copiés*



6

Rapport

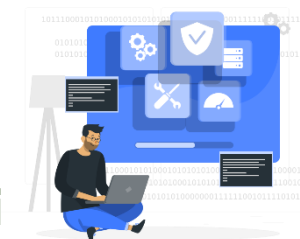
*des actions menées,
mise en évidence
des faits et
explication des
preuves numériques*



7

Suivi

*audit,
accompagnement,
déclaration*



55

Pourrait-on faire
l'impasse sur la
collecte de log

Dans ce cas, quel
log dois-je
prendre en
considération ?

LA COLLECTE DE DONNÉES

Faire l'impasse sur la collecte de log revient à ne rien pouvoir expliquer, ce qui est contraire à tous les principes de la réponse sur incident.



LA MÉTHODE DE
L'ENTONNOIR

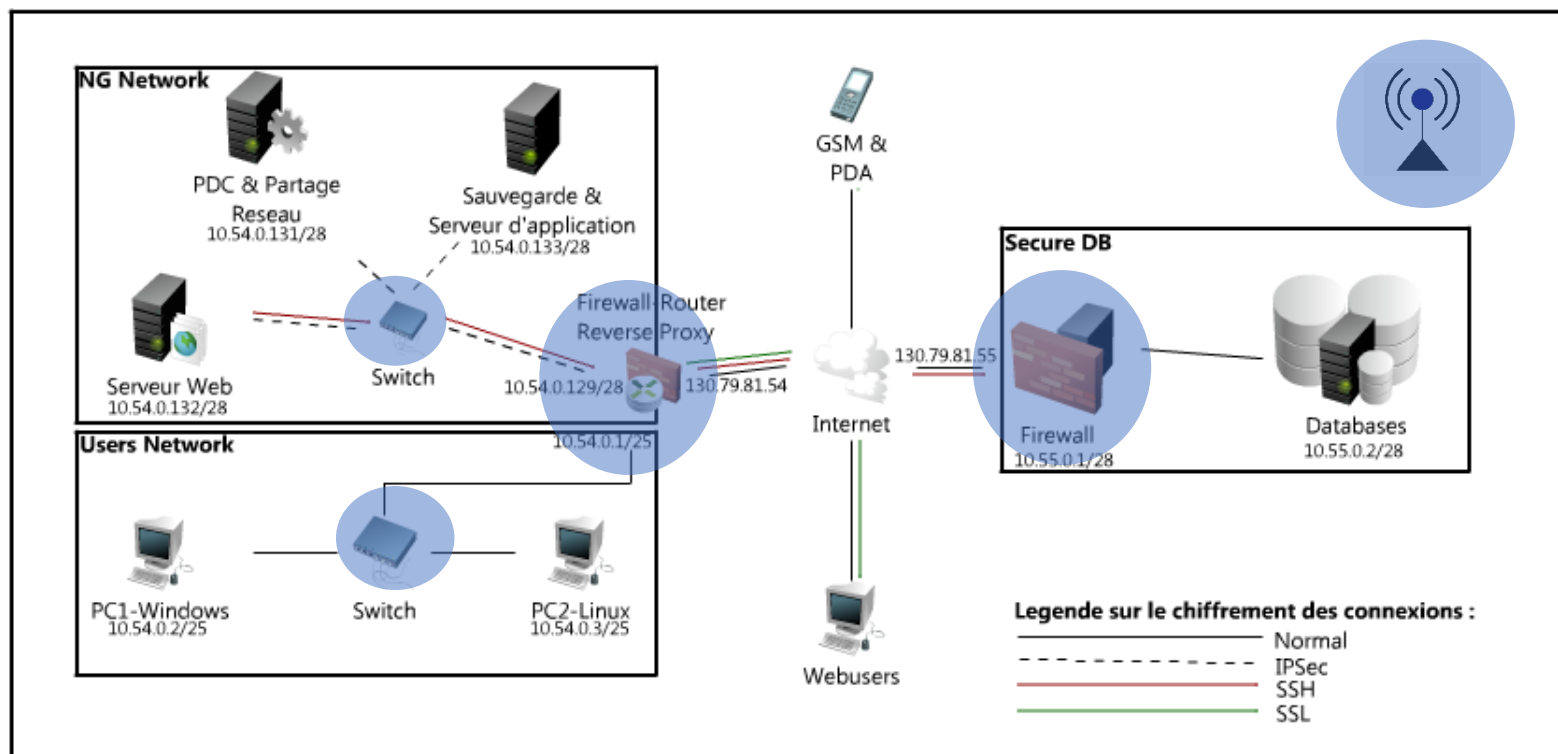
1. Journalisation des outils de surveillance (SIEM, parefeu, sonde, etc.)
2. Journalisation des outils de routage (routeur, switch, etc.)
3. Journalisation des services (LDAP, serveurs, etc.)
4. Journalisation des OS Endpoints

LA COLLECTE DE DONNÉES

LA MÉTHODE DE L'ENTONNOIR



**Données
explicatives sur
une entrée dans
l'architecture du SI**

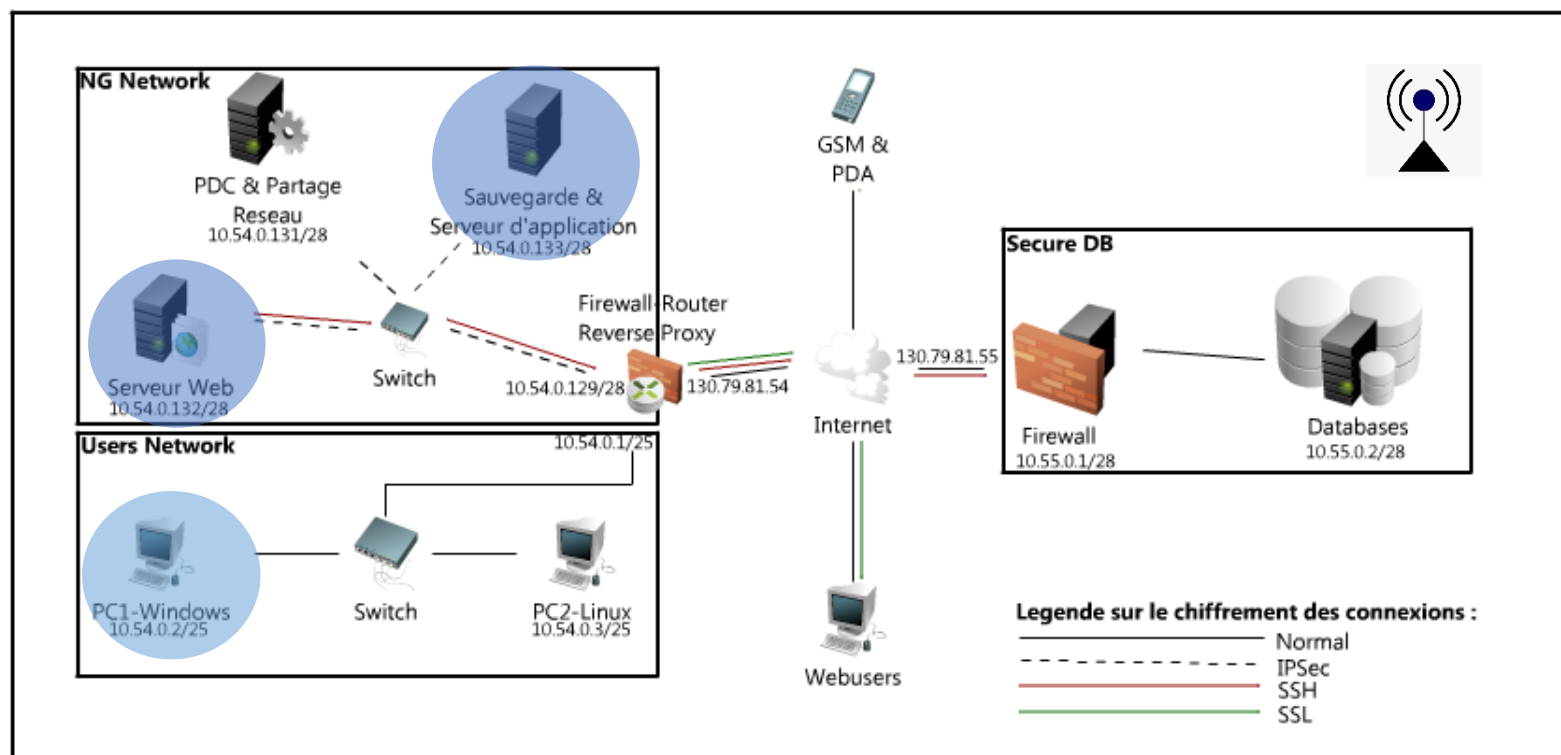


Objectif :

- ☐ Identifier,
- ☐ Collecter
- ☐ Analyser
- ☐ Cloisonner,

LA COLLECTE DE DONNÉES

LA MÉTHODE DE L'ENTONNOIR



**Données explicatives
sur une entrée dans
une machine
cloisonnée
physique ou virtualisée**

Objectif :

- ☐ Collecter
- ☐ Analyser
- ☐ Remédier

58

LA COLLECTE DE DONNÉES

La **collecte des données explicatives**, dans le cadre d'un processus de gestion des incidents de sécurité, constitue une activité clé pour répondre au « **critère de traçabilité** » inscrit dans le modèle DICT (Disponibilité, Intégrité, Confidentialité et Traçabilité).

Cette étape garantit une visibilité précise des événements, permettant une analyse rigoureuse et une réponse adaptée aux incidents tout en respectant les exigences de traçabilité.



LA COLLECTE DE DONNÉES



Définissez les principes du modèle DICT

☒ **Disponibilité**

☐ Intégrité

☐ Confidentialité

☐ Traçabilité

☐ La **disponibilité** désigne la capacité d'une information à être accessible et utilisable par son destinataire autorisé, au moment et à l'endroit prévus.

LA COLLECTE DE DONNÉES



Définissez les principes du modèle DICT

- ☐ Disponibilité
- ☒ **Intégrité**
- ☐ Confidentialité
- ☐ Traçabilité

- ☐ **L'intégrité** se rapporte à la garantie qu'une information ne peut être modifiée que par des personnes autorisées, et ce, selon des procédures définies.

61

LA COLLECTE DE DONNÉES



Définissez les principes du modèle DICT

- ☐ Disponibilité
- ☐ Intégrité
- ☒ Confidentialité
- ☐ Traçabilité

- ☐ La confidentialité est la propriété qui assure qu'une information n'est accessible qu'aux personnes disposant des autorisations nécessaires.

LA COLLECTE DE DONNÉES



Définissez les principes du modèle DICT

- ☐ Disponibilité
- ☐ Intégrité
- ☐ Confidentialité
- ☒ **Traçabilité**

- ☐ **La traçabilité** consiste à conserver les traces de l'état et des mouvements de l'information. Elle est essentielle, car sans elle, il est impossible de garantir que les trois autres critères (disponibilité, intégrité, et confidentialité) sont respectés.

63

Bonnes pratiques de la collecte de données

- Identifier les ressources explicatives (journaux)
- Mettre en place une politique de collecte (copie forensic)
- Mettre en place un service de stockages (sauvegarde sécurisée inaltérable)
- Mettre en place un dispositif de vérification (exercices)



Identifier



Collecter



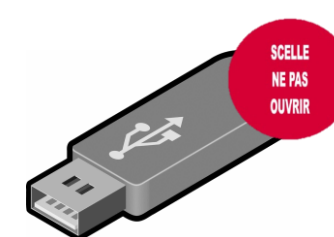
Sauvegarder



Vérifier



Bonnes pratiques de la collecte de données



Parmi les bonnes pratiques à mettre en place, **une politique des mesures conservatoires** paraît indispensable à qui doit justifier de la genèse d'un incident de sécurité sur le système d'information et de ses impacts sur l'entreprise. N'oublions pas que ces éléments sont destinés à permettre une **action en justice** et à **justifier du niveau de maturité** de votre système d'information au regard de certaines **exigences ou obligations légales**.



LA PREUVE NUMÉRIQUE

Définition de la preuve numérique

La « **preuve numérique** » représente toute information numérique pouvant être utilisée comme preuve dans une affaire de type judiciaire.

Les outils numériques, tels que les courriels et autres messageries (*SMS, WhatApps*), les empreintes numériques (*signature électronique*), des documents numériques (*contrat, comptabilité, planning,...*) ainsi que les traces numériques (*log*) sur le système d'information **constituent des éléments de preuve** nécessaire à la défense.



LA PREUVE NUMÉRIQUE

66



- ☐ Doit être suffisante,
- ☐ Doit avoir été obtenue sans fraude ni violence pour être admissible,
- ☐ Doit donc être loyale,
- ☐ Doit être écrite en cas d'acte juridique (action Civil) et est libre en cas de fait juridique ou d'infraction,
- ☐ On ne peut se constituer de preuve à soi-même en droit civil pour un acte juridique.
- ☐ La preuve en matière civile sera constatée par un **huissier de justice** qualifié ou assisté d'un **expert en informatique légale**.
- ☐ La preuve en matière pénale sera recueillie par un **expert en informatique (légale ou non, mandaté ou non)**. La preuve sera appréciée par le **juge pénal** en fonction de son **intime conviction**.

LA PREUVE NUMÉRIQUE

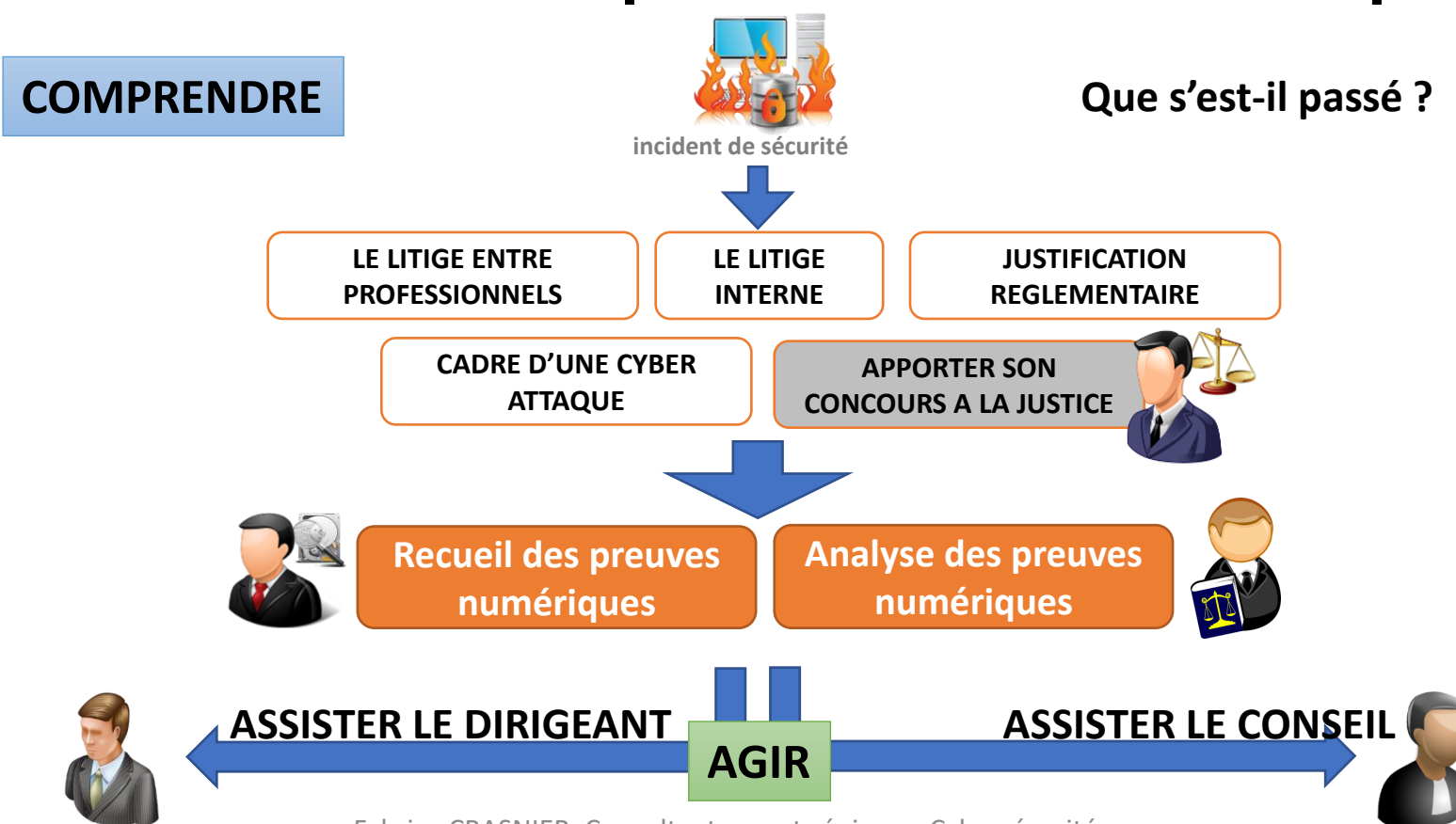
67

Comment protéger les preuves

- Faire **un gel des lieux numériques** sur un support de données par la fixation des preuves numériques dans le temps,
- Faire une **copie exacte des supports compromis** (copie bit à bit) en préservant le caractère inaltérable de la preuve,
- **Mettre en sécurité les données numériques** lors d'une cyberattaque avant la reprise d'activité,
- S'assurer que la collecte **des données** à analyser pourront servir de **preuve légale dans le cadre d'un litige**,
- S'assurer que les données prélevées seront de nature à **démontrer la « bonne foi »** de votre entreprise
- Procéder à l'analyse des données numériques, en **extraire les éléments matériels de la faute voire du délit ou du crime** aux fins d'une action juridique.

Qu'est-ce qu'un prestataire de réponse sur incident de sécurité ?

Missions et compétences attendues du personnel

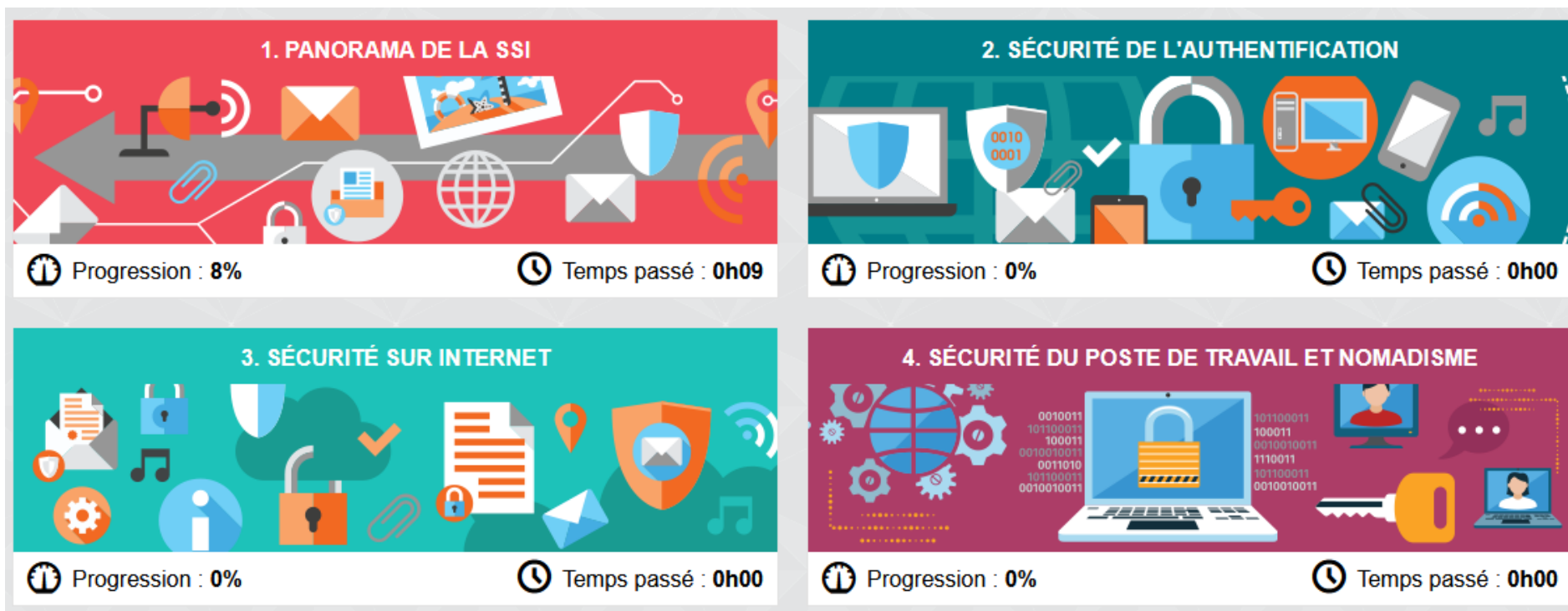


FORENSIC Expertises légales en informatique

L'expertise en informatique légale (*forensic*) est une investigation numérique légale qui a pour objet la **collecte de preuves numériques** afin de fournir la capacité à une personne de **soutenir une action en justice** ou de **faire reconnaître un droit**.

La formation peut-elle être une solution ?

MOOC : <https://secnumacademie.gouv.fr>



Merci de votre attention

A votre disposition pour un approfondissement

Maître de conférences associé

Doctorant en intelligence artificielle

Ecole doctorale MITT Mathématiques Informatique
Télécommunications de Toulouse.

Laboratoire IRIT - Equipe SMAC

Systèmes Multi-Agents Coopératifs

Avenue de l'étudiant, 31400 Toulouse

Courriel : fabrice.crasnier@irit.fr



UNIVERSITÉ
TOULOUSE III
PAUL SABATIER



Université
de Toulouse

Faculté
Sciences
et Ingénierie

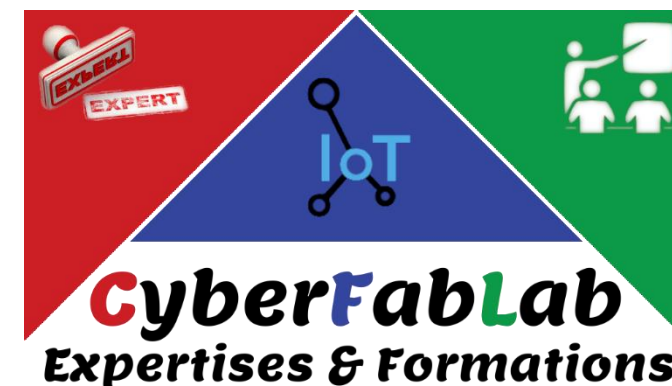
Domaines de compétences

- ☐ Formations en cybersécurité
- ☐ Réponse sur incident de sécurité
- ☐ Gestion de crise, conseil juridique
- ☐ Construction d'un dossier de plainte
- ☐ Expertises pénales et civiles



Ecole Doctorale Mathématiques, Informatique
et Télécommunications de Toulouse

Expert en Cybersécurité



Tel : 06.24.49.39.20

Courriel : fabrice.crasnier@cyberfablab.fr